

The tools saw it coming. Why didn't anyone act?

Lessons for Australian boards from the Optus, Medibank and Latitude Financial breaches



Why this matters now

Incidents are rising, and the 2022–23 breaches showed what one failure can cost

1,200+

incidents ASD responded to in 2024–25

+11% on the previous year

42,500+

calls to ASD’s cyber hotline

+16%

1,700+

times ASD warned organisations of malicious activity

+83%

Three breaches, millions of Australians affected



Optus (2022)

~9.5 million people

OAIC civil penalty action, 2025



Medibank (2022)

~9.7 million people

OAIC civil penalty action, 2024



Latitude (2023)

~14 million records

OAIC investigation ongoing; ~\$76m cost

Three breaches, three different failures

Facts below are as alleged or reported by regulators and official sources

Sept 2022



Optus

Internet-facing API with an access-control coding error (introduced 2018), fixed on the main site but not the subdomain

Way in: exposed system

Aug-Oct 2022



Medibank

Contractor's stolen login used on a VPN with no MFA; security alerts not triaged; ~520 GB taken

Way in: stolen credentials

Mar 2023



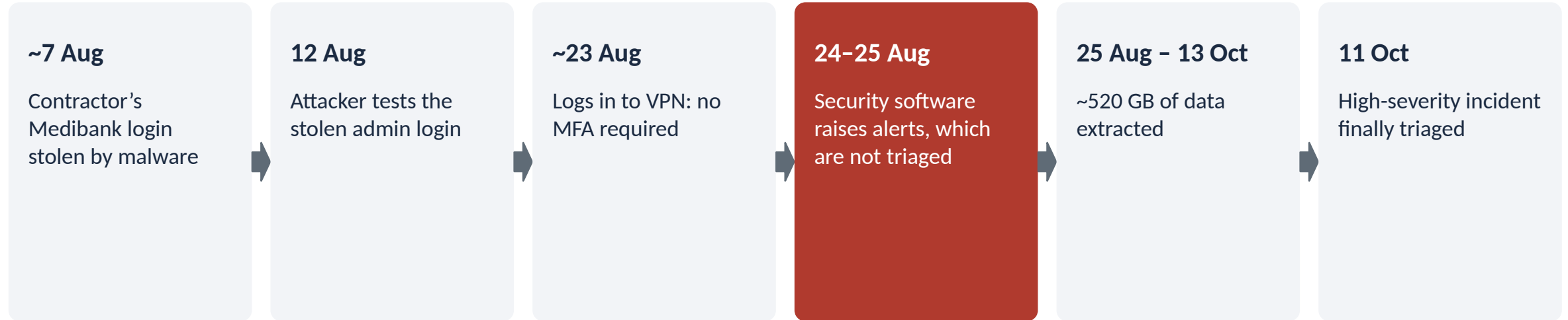
Latitude

Attack linked to credentials from a major vendor; old customer records dating back to 2005 exposed

Way in: third-party access

Medibank: the alarm rang, but nobody answered

Alleged timeline from the OAIC's Federal Court filing



Lesson: detection = tool × process × people.

The endpoint tool (EDR) did its job. The gap was ownership: alerts went to an inbox, and no one was accountable for acting on them. Research finds analysts see most alerts as false alarms, so alert fatigue is a predictable risk that needs managing (Alahmadi et al., 2022).

Comparing the four main investigation tools

Shading shows how favourable each rating is for the organisation

Tool (what it does)	Coverage	Accuracy	Cost	Skills needed	Integration	Prevent	Respond
SIEM: collects and correlates logs from everywhere	High	Medium	High	High	High	High	High
EDR/XDR: watches and isolates devices	Medium	High	Medium	Medium	Medium	High	High
Forensics (DFIR): reconstructs what happened	Targeted	High	Medium	Very high	Low	Low-Med	High
Threat intelligence: who is targeting us, and how	External	Variable	Medium	High	Medium	Medium	Low-Med

Favourable

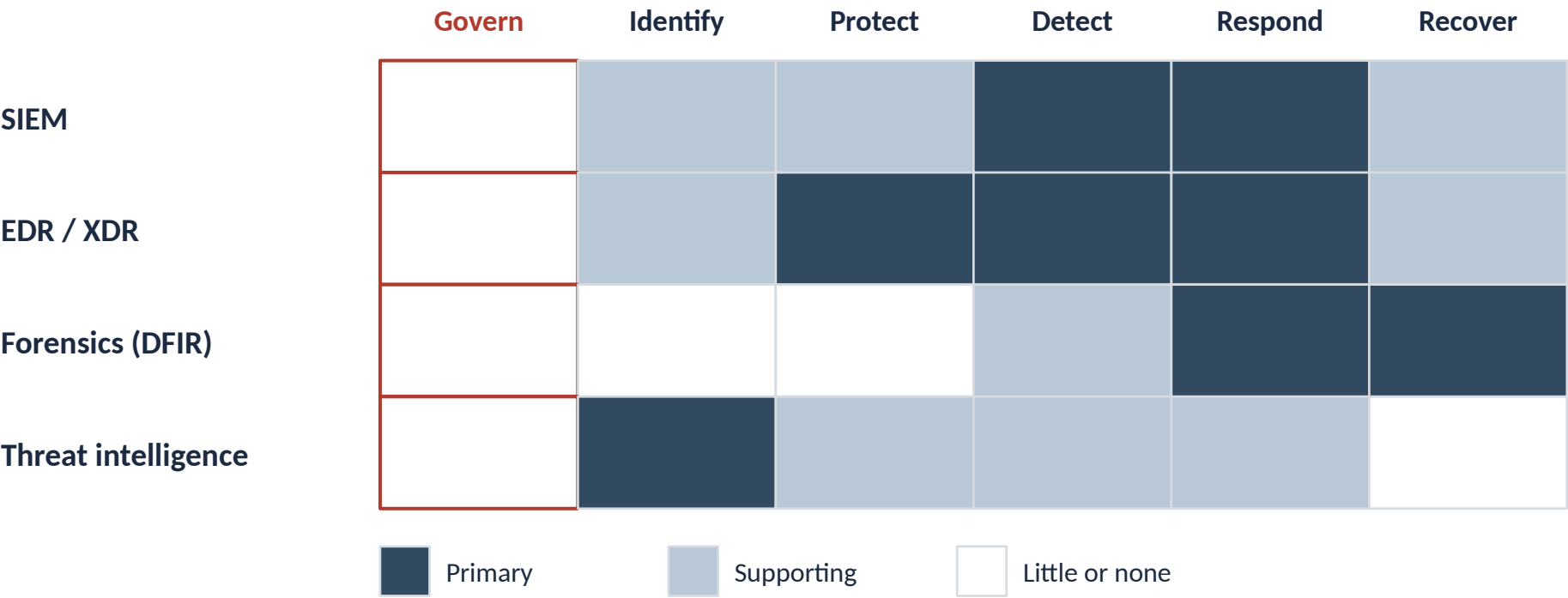
Moderate

Unfavourable

Takeaway: SIEM + EDR is the core. Forensics is bought when needed (on retainer). Threat intelligence only pays off once the basics work.

Mapped to NIST CSF 2.0: no tool covers "Govern"

Which framework functions each tool supports

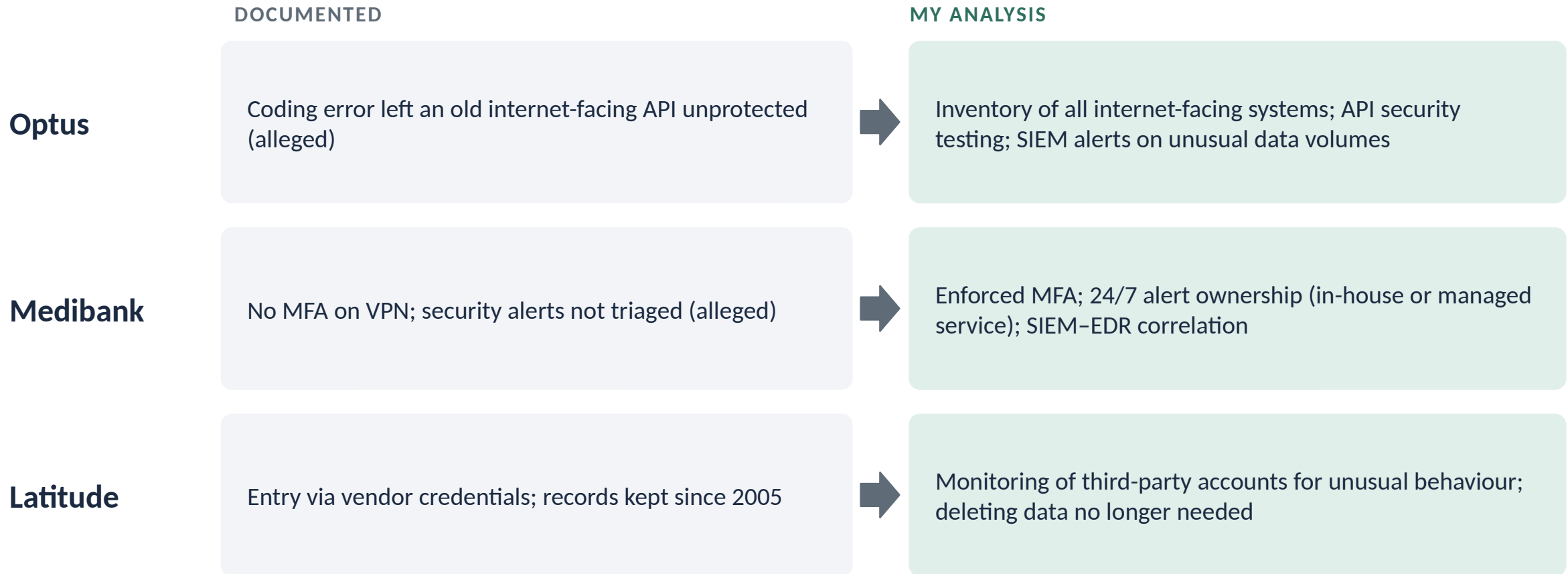


Govern is the board's job
Set risk appetite, own alert response, fund basics like MFA (Essential Eight). Tools can't do this for you.

Incident response is now treated as part of everyday risk management, not a separate emergency activity (NIST SP 800-61r3, 2025).

What would have changed the outcome?

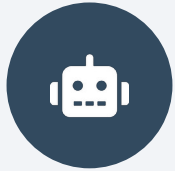
Left: documented facts. Right: my analysis of capabilities that could have helped



Pattern: none of the three was mainly a "missing tool" problem. Each was about visibility, identity and ownership.

What is changing for investigations

Four trends boards should plan for



AI on both sides

Attackers use AI for scams; AI can help triage alerts, but its findings must be explainable to stand up as evidence.



Identity is the new perimeter

Stolen logins and vendor access (Medibank, Latitude) move investigations to identity and cloud logs, which are often kept only briefly.



Tougher regulation

Ransomware payments must be reported within 72 hours (from 30 May 2025). A new privacy tort applies from 10 June 2025.



Skills shortage

Few organisations can staff 24/7 monitoring, so managed detection and response (MDR) services are growing.

Four actions, in priority order

Each one fixes a failure seen in the breaches

#	Action	What it involves	Owner	Investment	Timeframe	Fixes
1	Own every alert and enforce MFA	Phishing-resistant MFA on all remote access; 24/7 alert triage with escalation time limits (in-house or MDR)	CISO; board risk committee	Low-Medium	0-3 months	Medibank
2	Connect SIEM and EDR	Centralise identity, API, cloud and device logs to ASD's baseline; alerts for login misuse and bulk data access	CISO / CIO	Medium-High	3-9 months	Optus, Latitude
3	Be ready to investigate	Forensics firm on retainer; logs kept long enough to scope a breach; rehearse response plans	CISO; General Counsel	Medium	6-12 months	Latitude
4	Add threat intelligence last	Only once triage is mature; feed into risk assessment	Security operations lead	Medium	12+ months	All

Investment levels are relative estimates, not quotes. FAIR risk quantification can turn them into dollar figures for the board (Freund & Jones, 2015).

Three questions to ask on Monday



Who owns our security alerts
at 2 am on a Sunday?



Does every remote login
require MFA, including
contractors and vendors?



If we were breached today,
could we tell regulators within
days what was taken?

Bottom line: the right tools matter, but ownership, identity controls and readiness matter more.

Thank you. Questions?